

UNIVERSITÀ DEGLI STUDI DI SALERNO

DIPARTIMENTO DI INFORMATICA



Corso di Penetration Testing and Ethical Hacking

Penetration Testing Report

Docente:

**Prof.
Arcangelo
CASTIGLIONE**

Studente:

**Pasquale
SORRENTINO**
Mat. 0522501954

ANNO ACCADEMICO 2025/2026

CONTENTS

1	Executive Summary	3
1.1	Perimetro e metodologia del test	3
1.2	Risultati principali	4
1.3	Valutazione complessiva del rischio	5
2	Engagement Highlights	7
2.1	Regole di ingaggio	7
2.2	Tempistiche e responsabilità operative	8
2.3	Vincoli operativi	8
3	Vulnerability Report	10
3.1	Credenziali esposte nel codice sorgente della pagina web	10
3.2	Accesso non autorizzato al servizio Usermin	11
3.3	Command Shell disponibile tramite Usermin	11
3.4	Privilege Escalation tramite CVE-2022-0847 Dirty Pipe	12
3.5	Capability eccessivamente permissiva sul file tar	12
3.6	Configurazioni deboli del servizio HTTP	13
3.7	Information Disclosure tramite servizio SMB	13
3.8	Valutazione complessiva	14

CONTENTS

4	4-Remediation Report	15
4.1	Rimozione di credenziali e informazioni sensibili dal codice sorgente	15
4.2	Protezione dell'accesso a Usermin	15
4.3	Limitazione della Command Shell tramite Usermin	16
4.4	Aggiornamento del kernel e mitigazione di CVE-2022-0847 . . .	16
4.5	Revisione delle capabilities assegnate ai file	17
4.6	Hardening del servizio HTTP	17
4.7	Limitazione dell'enumerazione SMB	18
5	Findings Summary	19
5.1	Metodologia e strumenti	19
5.2	Classificazione delle vulnerabilità	20
5.3	Overview dei findings	21
6	Detailed Summary	23
6.1	FND-001 – Credenziali esposte nel codice sorgente	23
6.2	FND-002 – Accesso non autorizzato al servizio Usermin	24
6.3	FND-003 – Command Shell disponibile tramite Usermin	25
6.4	FND-004 – Privilege Escalation tramite CVE-2022-0847 Dirty Pipe	26
6.5	FND-005 – Capability eccessivamente permissiva sul file tar . .	27
6.6	FND-006 – SMB Signing non obbligatorio	28
6.7	FND-007 – Information Disclosure tramite servizio SMB	29
6.8	FND-008 – Header HTTP di sicurezza mancanti	30
6.9	FND-009 – Directory web navigabili	30
6.10	FND-010 – Esposizione di informazioni di versione	31
6.11	FND-011 – ICMP Timestamp Disclosure	32
	References	34

CHAPTER 1

EXECUTIVE SUMMARY

1.1 Perimetro e metodologia del test

Il presente report riassume i risultati dell'attività di penetration testing condotta sulla macchina virtuale vulnerabile *Empire: Breakout*, utilizzata come caso di studio nell'ambito del corso di *Penetration Testing and Ethical Hacking*.

L'attività è stata svolta in un ambiente di laboratorio controllato e autorizzato, realizzato tramite Oracle VirtualBox. Il perimetro del test è stato limitato esclusivamente alla macchina target *Empire: Breakout*, identificata all'indirizzo IP **10.0.2.3**, e alla rete virtuale locale configurata per l'esercitazione. Sono state escluse dallo scope tutte le attività rivolte a sistemi esterni, reti non autorizzate o asset non direttamente riconducibili al caso di studio.

Il penetration test è stato condotto adottando un approccio di tipo *black-box*. All'inizio dell'attività non erano quindi disponibili informazioni tecniche dettagliate sul target, come indirizzo IP, servizi esposti, credenziali o vulnerabilità presenti. Le informazioni necessarie sono state raccolte progressivamente attraverso attività di ricognizione, discovery, enumerazione, vulnerability mapping, exploitation e post-exploitation.

La metodologia adottata ha seguito le principali fasi del *Framework Generale per il Penetration Testing*, con l'obiettivo di mantenere un processo ordinato, documentato e replicabile.

1.2 Risultati principali

L'attività di analisi ha permesso di individuare la macchina target all'interno della rete di laboratorio e di identificare diversi servizi esposti. In particolare, sono state rilevate porte TCP aperte associate a servizi HTTP, SMB/Samba, Webmin e Usermin.

L'enumerazione dei servizi ha evidenziato la presenza di un server web Apache su Debian, di servizi Samba sulle porte **139/tcp** e **445/tcp**, e di interfacce web di autenticazione sulle porte **10000/tcp** e **20000/tcp**. L'analisi del codice sorgente della pagina web principale ha permesso di individuare un commento contenente una stringa codificata, successivamente interpretata come possibile password.

Attraverso l'enumerazione SMB è stato individuato l'utente **cyber**. Combinando tale username con la password ricavata dalla stringa codificata, è stato possibile effettuare l'accesso al servizio Usermin esposto sulla porta **20000/tcp**. L'accesso al servizio Webmin sulla porta **10000/tcp**, invece, non è andato a buon fine.

Una volta ottenuto l'accesso a Usermin, è stato possibile utilizzare funzionalità sensibili, tra cui una command shell web e funzionalità di upload/download di file. Tali funzionalità hanno consentito l'esecuzione di comandi sul sistema target e l'ottenimento di una reverse shell.

Durante la fase di post-exploitation è stata individuata la possibilità di effettuare una privilege escalation. In particolare, è stata sfruttata la vulnerabilità locale **CVE-2022-0847**, nota come *Dirty Pipe*, ottenendo privilegi di **root** sulla macchina target.

Infine, è stata dimostrata la possibilità di predisporre un meccanismo di persistenza tramite una backdoor avviata automaticamente mediante servizio

systemd. Questo ha permesso di verificare l'impatto di una compromissione completa del sistema.

1.3 Valutazione complessiva del rischio

Il livello di rischio complessivo associato alla macchina target è stato valutato come **critico**. Tale valutazione deriva dal fatto che le vulnerabilità e le configurazioni deboli individuate hanno consentito di passare da una fase iniziale di ricognizione esterna alla compromissione completa del sistema.

Gli elementi più rilevanti che contribuiscono alla valutazione del rischio sono:

- esposizione di servizi amministrativi accessibili via web;
- presenza di informazioni sensibili all'interno del codice sorgente della pagina web;
- individuazione di un utente valido tramite enumerazione SMB;
- accesso riuscito al servizio Usermin tramite credenziali recuperate;
- disponibilità di una command shell web per l'utente autenticato;
- presenza di una vulnerabilità locale sfruttabile per ottenere privilegi di root;
- possibilità di predisporre un meccanismo persistente di accesso al sistema.

La combinazione di questi fattori ha reso possibile una compromissione progressiva dell'asset, fino al pieno controllo della macchina. In un contesto reale, una situazione simile potrebbe consentire a un attaccante di accedere a dati sensibili, modificare configurazioni di sistema, installare componenti persistenti, compromettere ulteriori asset interni o interrompere la disponibilità dei servizi.

Si raccomanda pertanto di intervenire prioritariamente sulla rimozione delle informazioni sensibili esposte, sull'aggiornamento del sistema operativo e dei

1. EXECUTIVE SUMMARY

servizi vulnerabili, sulla limitazione dell'accesso alle interfacce amministrative e sulla revisione delle configurazioni di sicurezza dei servizi web e SMB.

CHAPTER 2

ENGAGEMENT HIGHLIGHTS

2.1 Regole di ingaggio

L'attività di penetration testing è stata condotta esclusivamente all'interno di un ambiente di laboratorio controllato e autorizzato, predisposto per finalità didattiche nell'ambito del corso di *Penetration Testing and Ethical Hacking*.

Il perimetro dell'attività è stato limitato alla macchina virtuale vulnerabile *Empire: Breakout*, identificata durante il test con indirizzo IP **10.0.2.3**, e alla rete virtuale locale configurata tramite Oracle VirtualBox. Non sono state previste né eseguite attività verso sistemi esterni, reti pubbliche, host di terze parti o asset non riconducibili al laboratorio.

Il test è stato svolto adottando un approccio di tipo *black-box*, simulando quindi una condizione iniziale in cui il tester non disponeva di informazioni tecniche dettagliate sul target. Le informazioni utilizzate durante l'attività sono state raccolte progressivamente attraverso le fasi di ricognizione, discovery, enumerazione e analisi delle vulnerabilità.

Le attività di exploitation e post-exploitation sono state eseguite unicamente per verificare l'effettiva sfruttabilità delle debolezze individuate e per valutare

l'impatto della compromissione. Tutte le operazioni sono state documentate e mantenute entro i limiti dello scope autorizzato.

2.2 Tempistiche e responsabilità operative

L'attività di penetration testing è stata svolta dallo studente **Pasquale Sorrentino** nell'ambito del progetto previsto per il corso di *Penetration Testing and Ethical Hacking*.

Il periodo operativo previsto per lo svolgimento del test ha avuto inizio in data **31/05/2026** e si è concluso entro il **15/06/2026**, con la produzione della documentazione richiesta e dei deliverable associati.

Le attività principali hanno incluso la configurazione dell'ambiente di laboratorio, l'identificazione del target, l'enumerazione dei servizi esposti, l'analisi delle vulnerabilità, la verifica dei vettori di attacco, l'ottenimento dell'accesso al sistema e la valutazione delle possibilità di escalation e persistenza.

I deliverable previsti comprendono il presente *Penetration Testing Report*, il documento tecnico di dettaglio relativo al processo svolto e il materiale di presentazione finale. Il presente report si concentra sui risultati ottenuti, sulle vulnerabilità individuate, sul relativo impatto e sulle raccomandazioni di mitigazione.

2.3 Vincoli operativi

L'attività è stata soggetta a specifici vincoli operativi, definiti al fine di garantire che il test fosse svolto in modo sicuro, controllato ed eticamente corretto.

In particolare, sono state escluse dal perimetro:

- scansioni o tentativi di accesso verso sistemi esterni alla rete virtuale di laboratorio;
- attività rivolte ad asset non esplicitamente autorizzati;

2. ENGAGEMENT HIGHLIGHTS

- attacchi di tipo denial of service o attività finalizzate all'interruzione dei servizi;
- cancellazione, alterazione distruttiva o compromissione irreversibile dei dati presenti sul target;
- utilizzo delle tecniche sperimentate su sistemi reali o non autorizzati.

Le attività di post-exploitation, incluse privilege escalation e persistenza, sono state eseguite esclusivamente per finalità dimostrative e per valutare l'impatto tecnico di una compromissione completa. Ogni attività è stata condotta all'interno della macchina vulnerabile *by design* e documentata nel rispetto degli obiettivi del progetto.

CHAPTER 3

VULNERABILITY REPORT

3.1 Credenziali esposte nel codice sorgente della pagina web

Severità: Critica

Durante l'analisi manuale del servizio HTTP esposto sulla porta **80/tcp**, è stata individuata una pagina di default Apache2. L'ispezione del codice sorgente della pagina ha evidenziato la presenza di un commento HTML contenente una stringa codificata.

La stringa è stata successivamente analizzata e decodificata. Tale valore è risultato utilizzabile come password in combinazione con l'utente **cyber**, individuato tramite enumerazione SMB.

La presenza di credenziali, anche se offuscate, all'interno del codice sorgente di una pagina web rappresenta una vulnerabilità critica, poiché consente a un attaccante di recuperare informazioni sensibili senza necessità di autenticazione.

L'impatto della vulnerabilità è stato confermato dal successivo accesso al servizio Usermin esposto sulla porta **20000/tcp**.

3.2 Accesso non autorizzato al servizio Usermin

Severità: Critica

Il servizio **Usermin**, esposto sulla porta **20000/tcp**, presentava una pagina di autenticazione accessibile dalla rete di laboratorio. Utilizzando le credenziali ricavate nel codice sorgente della pagina web, è stato possibile effettuare l'accesso con successo.

L'accesso al servizio Usermin ha permesso di interagire con un'interfaccia contenente funzionalità sensibili, tra cui gestione dell'account, accesso alla posta, upload e download di file e command shell web.

Questa vulnerabilità ha rappresentato il principale punto di ingresso nel sistema target. L'impatto è elevato, poiché un attaccante autenticato può eseguire comandi sul sistema con i privilegi dell'utente compromesso e avviare ulteriori attività di post-exploitation.

3.3 Command Shell disponibile tramite Usermin

Severità: Critica

Dopo l'accesso al servizio Usermin, è stata individuata una funzionalità di *Command Shell* accessibile all'utente autenticato. Tale funzionalità ha consentito l'esecuzione di comandi direttamente sulla macchina target con i privilegi dell'utente **cyber**.

La disponibilità di una shell web rappresenta una criticità significativa, poiché trasforma un accesso applicativo in un accesso operativo al sistema.

3.4 Privilege Escalation tramite CVE-2022-0847 Dirty Pipe

Severità: Critica

Durante la fase di post-exploitation è stata identificata la versione del kernel Linux in uso sulla macchina target. Tale informazione ha permesso di valutare la presenza di vulnerabilità locali note potenzialmente sfruttabili per l'escalation dei privilegi.

È stata verificata la possibilità di sfruttare la vulnerabilità **CVE-2022-0847**, nota come *Dirty Pipe*. Questa vulnerabilità interessa specifiche versioni del kernel Linux e può consentire a un utente locale non privilegiato di sovrascrivere dati associati a file di sola lettura, con possibile escalation dei privilegi.

3.5 Capability eccessivamente permissiva sul file tar

Severità: Alta

Durante l'analisi locale del sistema è stato individuato un file denominato **tar**, appartenente all'utente **root**, associato alla capability:

```
cap_dac_read_search=ep
```

Le capabilities in Linux permettono di assegnare a specifici eseguibili privilegi particolari senza dover necessariamente eseguire il programma come root. Nel caso specifico, la capability individuata consente di leggere file e attraversare directory ignorando le normali restrizioni dei permessi.

Questa configurazione rappresenta una debolezza significativa, poiché potrebbe permettere a un utente non privilegiato di leggere file sensibili normalmente non accessibili.

3.6 Configurazioni deboli del servizio HTTP

Severità: Media

L'analisi del servizio HTTP esposto sulla porta **80/tcp** ha evidenziato diverse configurazioni deboli. In particolare, sono stati rilevati header di sicurezza mancanti o non configurati correttamente, esposizione della pagina di default Apache2 e presenza della directory `/manual/` accessibile dal web server.

Tra le principali debolezze rilevate rientrano:

- assenza di header di sicurezza come *Content-Security-Policy* e *X-Frame-Options*;
- esposizione della versione del server Apache;
- directory e risorse che restituiscono informazioni utili sul comportamento del server.

Queste debolezze non hanno rappresentato da sole un punto di compromissione diretto, ma hanno contribuito alla raccolta di informazioni utili per le fasi successive del test.

3.7 Information Disclosure tramite servizio SMB

Severità: Media

Durante l'analisi dei servizi SMB/Samba esposti sulle porte **139/tcp** e **445/tcp**, è stata effettuata un'attività di enumerazione che ha permesso di ottenere informazioni relative al sistema target, tra cui il nome NetBIOS della macchina e la presenza dell'utente locale **cyber**. La possibilità di enumerare utenti locali tramite SMB rappresenta una debolezza di sicurezza, poiché fornisce a un attaccante informazioni utili per costruire successivi tentativi di accesso. In particolare, la conoscenza di un username valido riduce significativamente lo sforzo necessario per effettuare attacchi di autenticazione,

password guessing o correlazione con credenziali recuperate da altre fonti. L'impatto della vulnerabilità è quindi da considerarsi significativo all'interno della catena di compromissione, pur non rappresentando da sola un accesso diretto al sistema.

3.8 Valutazione complessiva

Le vulnerabilità individuate mostrano una catena di compromissione completa. L'esposizione di informazioni sensibili nel codice sorgente ha consentito di recuperare una password; l'enumerazione SMB ha permesso di individuare un utente valido; l'accesso a Usermin ha fornito una command shell; infine, una vulnerabilità locale del kernel ha permesso di ottenere privilegi di root.

La criticità complessiva del sistema è quindi valutata come **critica**, poiché un attaccante sarebbe in grado di passare da una posizione esterna non autenticata al pieno controllo della macchina target.

CHAPTER 4

4-REMEDIATION REPORT

4.1 Rimozione di credenziali e informazioni sensibili dal codice sorgente

Le credenziali, anche se codificate o offuscate, non devono mai essere inserite all'interno del codice sorgente di pagine web, commenti HTML, file pubblicamente accessibili o risorse servite dal web server.

Eventuali password, token, chiavi o stringhe di configurazione devono essere gestite tramite meccanismi sicuri, come variabili d'ambiente, secret manager o file di configurazione non accessibili dal web server.

Inoltre, le credenziali compromesse devono essere considerate non più affidabili e devono essere sostituite.

4.2 Protezione dell'accesso a Usermin

Il servizio **Usermin**, esposto sulla porta **20000/tcp**, ha rappresentato il principale punto di ingresso alla macchina target.

Si raccomanda di limitarne l'accessibilità solo agli host e agli utenti strettamente autorizzati.

In particolare, è opportuno:

- limitare l'accesso alla porta **20000/tcp** tramite firewall;
- impedire l'esposizione del servizio su reti non fidate;
- utilizzare password robuste e non riutilizzate;
- abilitare, ove possibile, meccanismi di autenticazione multifattore;
- monitorare i tentativi di login falliti e gli accessi anomali;
- mantenere Usermin aggiornato all'ultima versione stabile disponibile.

4.3 Limitazione della Command Shell tramite Usermin

La disponibilità di una *Command Shell* accessibile tramite Usermin aumenta in modo significativo l'impatto di una compromissione dell'account utente.

Si raccomanda di disabilitare tale funzionalità per gli utenti che non necessitano esplicitamente di eseguire comandi sul sistema.

È inoltre opportuno applicare il principio del minimo privilegio, limitando le operazioni eseguibili dagli utenti autenticati e monitorando eventuali comandi sospetti o non coerenti con l'utilizzo previsto del sistema.

4.4 Aggiornamento del kernel e mitigazione di CVE-2022-0847

La vulnerabilità **CVE-2022-0847**, nota come *Dirty Pipe*, ha consentito l'escalation dei privilegi fino all'utente **root**. Per mitigare questa criticità, è necessario aggiornare il kernel Linux a una versione non vulnerabile.

Si raccomanda di:

- applicare gli aggiornamenti di sicurezza forniti dalla distribuzione;
- implementare un processo periodico di patch management;
- monitorare la presenza di vulnerabilità locali note sui sistemi esposti.

4.5 Revisione delle capabilities assegnate ai file

Il file `tar` individuato sul sistema presentava la capability `cap_dac_read_search=ep`, che consente di leggere file e attraversare directory ignorando le normali restrizioni dei permessi.

Si raccomanda di rimuovere tale capability, salvo che non sia strettamente necessaria per specifiche esigenze operative.

È inoltre opportuno eseguire una revisione completa delle capabilities assegnate agli eseguibili presenti sul sistema.

L'obiettivo è individuare eventuali permessi eccessivi o non giustificati, riducendo il rischio di utilizzo improprio da parte di utenti non privilegiati.

4.6 Hardening del servizio HTTP

Il servizio HTTP esposto sulla porta **80/tcp** ha mostrato diverse configurazioni deboli, tra cui directory accessibili e assenza di alcuni header di sicurezza.

Si raccomanda di:

- disabilitare il directory listing;
- ridurre l'esposizione di banner e informazioni sulla versione del server;
- configurare header di sicurezza come *Content-Security-Policy*, *X-Frame-Options*, *X-Content-Type-Options* e *Referrer-Policy*;

- abilitare HTTPS con certificati validi, ove applicabile.

Queste misure riducono l'esposizione informativa e limitano la possibilità per un attaccante di raccogliere dettagli utili alla costruzione di ulteriori attacchi.

4.7 Limitazione dell'enumerazione SMB

L'enumerazione dei servizi SMB/Samba ha permesso di ottenere informazioni utili sul sistema target, tra cui il nome NetBIOS della macchina e la presenza dell'utente locale **cyber**.

Per ridurre il rischio di information disclosure tramite SMB, si raccomanda di:

- disabilitare l'accesso anonimo ai servizi SMB;
- limitare l'accesso alle porte **139/tcp** e **445/tcp** tramite firewall;
- consentire l'accesso SMB solo da host o reti fidate;
- verificare la configurazione del file `smb.conf`;
- limitare la visibilità di utenti, gruppi e condivisioni;
- disabilitare condivisioni non necessarie.

CHAPTER 5

FINDINGS SUMMARY

5.1 Metodologia e strumenti

L'individuazione dei findings è stata effettuata adottando una metodologia ibrida, basata sull'utilizzo combinato di strumenti automatici e verifiche manuali. I risultati prodotti dagli strumenti sono stati successivamente analizzati e correlati al fine di individuare le vulnerabilità effettivamente rilevanti per la sicurezza dell'asset.

Durante l'attività sono stati utilizzati strumenti differenti in base alla fase di analisi:

- **Nmap**, per l'individuazione delle porte aperte, dei servizi esposti e delle relative versioni;
- **Nikto**, **Nessus** e **OWASP ZAP**, per l'identificazione di vulnerabilità note, configurazioni deboli e problematiche applicative;
- **DIRB** e **dirsearch**, per attività di content discovery e individuazione di directory o file accessibili;
- **smbclient** ed **enum4linux**, per l'enumerazione dei servizi SMB/Samba;

5. FINDINGS SUMMARY

- **searchsploit**, per la ricerca manuale di exploit pubblici associati ai servizi rilevati;
- **Metasploit**, per la validazione controllata di alcuni vettori di exploitation e post-exploitation.

Alcune segnalazioni sono state rilevate da più strumenti con nomi differenti. In questi casi, i risultati sono stati accorpati in findings consolidati, evitando duplicazioni e mantenendo solo le evidenze più significative ai fini della valutazione del rischio.

5.2 Classificazione delle vulnerabilità

I findings individuati sono stati classificati secondo quattro livelli di severità:

- **Critical:** vulnerabilità che consentono accesso non autorizzato, esecuzione di comandi, escalation dei privilegi o compromissione completa dell'asset;
- **High:** vulnerabilità ad alto impatto, potenzialmente utilizzabili per accedere a informazioni sensibili o facilitare attività successive;
- **Medium:** debolezze che aumentano la superficie d'attacco, favoriscono l'enumerazione o riducono il livello di hardening del sistema;
- **Low:** finding informativi o di hardening, con impatto diretto limitato ma utili per migliorare la postura di sicurezza complessiva.

La classificazione tiene conto non solo della severità tecnica della singola vulnerabilità, ma anche del ruolo che essa ha avuto nella catena di compromissione osservata durante il test.

5.3 Overview dei findings

Complessivamente sono stati identificati **11 findings**, distribuiti come segue:

- **4 Critical;**
- **2 High;**
- **2 Medium;**
- **3 Low.**

La distribuzione dei findings evidenzia una concentrazione significativa di vulnerabilità critiche, alcune delle quali sono state effettivamente sfruttate durante il test per ottenere accesso al sistema, eseguire comandi e raggiungere privilegi amministrativi.

5. FINDINGS SUMMARY

Finding	Severità	Categoria
Credenziali esposte nel codice sorgente	Critical	Information Disclosure / Credential Exposure
Accesso non autorizzato a Usermin	Critical	Unauthorized Access
Command Shell tramite Usermin	Critical	Remote Command Execution
CVE-2022-0847 Dirty Pipe	Critical	Privilege Escalation
Capability eccessiva sul file tar	High	Local Misconfiguration
SMB Signing non obbligatorio	High	SMB Misconfiguration
Information Disclosure tramite SMB	Medium	Enumeration / Information Disclosure
Header HTTP di sicurezza mancanti	Medium	Web Hardening
Directory web navigabili	Low	Web Information Disclosure
Esposizione di informazioni di versione	Low	Service Fingerprinting
ICMP Timestamp Disclosure	Low	Network Information Disclosure

Table 5.1: Overview dei findings individuati

CHAPTER 6

DETAILED SUMMARY

In questo capitolo vengono descritti nel dettaglio i principali findings individuati, gli stessi sono organizzati in ordine decrescente di severità, partendo dai finding critici fino ad arrivare agli elementi di rischio inferiore o principalmente riconducibili ad aspetti di hardening.

Per ciascun finding vengono riportati, gli asset interessati, una descrizione del problema, la *Proof of Concept* (PoC) sintetica, il possibile impatto sull'asset, le azioni correttive raccomandate, gli strumenti utilizzati e i relativi riferimenti.

6.1 FND-001 – Credenziali esposte nel codice sorgente

Severità: Critical

Asset Interessato: Porta 80/tcp

Descrizione: Durante l'analisi manuale del servizio HTTP esposto sulla porta 80/tcp, è stata individuata una pagina di default Apache2. L'ispezione del codice sorgente ha evidenziato la presenza di un commento HTML contenente una stringa codificata. La stringa è stata successivamente decodificata e il valore ottenuto è risultato utilizzabile come password per l'accesso al servizio

Usermin.

PoC: Analisi manuale del codice sorgente della pagina web e successiva decodifica della stringa individuata. Il finding è stato supportato anche dalle segnalazioni relative ai commenti sospetti individuate durante l'analisi applicativa.

Impatto: La presenza di informazioni sensibili nel codice sorgente consente a un attaccante non autenticato di recuperare credenziali o elementi utili per l'autenticazione. Nel caso analizzato, la password recuperata è stata combinata con l'utente **cyber**, individuato tramite enumerazione SMB, consentendo l'accesso al servizio Usermin.

Soluzione: Rimuovere immediatamente credenziali, token, chiavi o stringhe sensibili dal codice sorgente e dai commenti HTML. Le credenziali devono essere archiviate in modo sicuro, in file non accessibili via web o tramite secret manager. Le credenziali esposte devono essere considerate compromesse e sostituite.

Strumenti utilizzati: Funzionalità *Ispeziona* del browser, OWASP ZAP, analisi manuale.

Riferimenti: CWE-615¹ – Inclusion of Sensitive Information in Source Code Comments.

CWE-798² – Use of Hard-coded Credentials;

6.2 FND-002 – Accesso non autorizzato al servizio Usermin

Severità: Critical

Asset Interessato: Porta 20000/tcp

Descrizione: Il servizio **Usermin**, esposto sulla porta 20000/tcp, presentava una pagina di autenticazione accessibile dalla rete di laboratorio. Utilizzando le credenziali ricavate, è stato possibile effettuare l'accesso con

¹CWE-615. URL: <https://cwe.mitre.org/data/definitions/615.html>.

²CWE-798. URL: <https://cwe.mitre.org/data/definitions/798.html>.

successo all'interfaccia web del servizio.

PoC: È stato effettuato un tentativo di autenticazione manuale sul pannello Usermin utilizzando l'utente **cyber** e la password ottenuta dalla decodifica della stringa presente nel codice sorgente della pagina web. L'accesso è stato completato con successo.

Impatto: L'accesso a Usermin ha consentito l'interazione con funzionalità sensibili, tra cui gestione dell'account, posta, upload/download di file e command shell. Tale accesso ha rappresentato il principale punto di ingresso nel sistema target.

Soluzione: Limitare l'accesso a Usermin ai soli host autorizzati tramite firewall o regole di rete. Utilizzare password robuste e non riutilizzate, abilitare ove possibile l'autenticazione multifattore, aggiornare il servizio e disabilitarlo se non strettamente necessario.

Strumenti utilizzati: Browser web, Nmap, analisi manuale.

Riferimenti: CWE-287³: Improper Authentication;

CWE-306⁴: Missing Authentication for Critical Function.

6.3 FND-003 – Command Shell disponibile tramite Usermin

Severità: Critical

Asset Interessato: Servizio Usermin, porta **20000/tcp**

Descrizione: Dopo l'accesso al servizio Usermin, è stata individuata una funzionalità di *Command Shell* accessibile all'utente autenticato. Tale funzionalità ha consentito l'esecuzione di comandi direttamente sulla macchina target con i privilegi dell'utente **cyber**.

PoC: Dall'interfaccia Usermin è stata aperta la sezione relativa alla command shell ed è stata verificata la possibilità di eseguire comandi non distruttivi sul sistema. Successivamente, la stessa funzionalità è stata utilizzata per ottenere

³CWE-287. URL: <https://cwe.mitre.org/data/definitions/287.html>.

⁴CWE-306. URL: <https://cwe.mitre.org/data/definitions/306.html>.

una reverse shell verso la macchina attaccante.

Impatto: La disponibilità di una shell web trasforma un accesso applicativo in un accesso operativo al sistema. Un attaccante autenticato può eseguire comandi, esplorare il filesystem, raccogliere informazioni locali e predisporre attività successive di exploitation o post-exploitation.

Soluzione: Disabilitare la funzionalità di command shell per gli utenti non amministrativi o non strettamente autorizzati. Applicare il principio del minimo privilegio, abilitare logging dettagliato dei comandi eseguiti e monitorare eventuali attività anomale.

Strumenti utilizzati: Usermin, browser web, Netcat, Metasploit.

Riferimenti: CWE-78⁵: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection').

6.4 FND-004 – Privilege Escalation tramite CVE-2022-0847 Dirty Pipe

Severità: Critical

Asset Interessato: Sistema operativo Linux / Kernel **5.10.0-9-amd64**

Descrizione: Durante la fase di post-exploitation è stata identificata la versione del kernel Linux in uso sulla macchina target. La versione individuata è risultata compatibile con lo sfruttamento della vulnerabilità **CVE-2022-0847**, nota come *Dirty Pipe*. Tale vulnerabilità può consentire a un utente locale non privilegiato di ottenere un'escalation dei privilegi.

PoC: Dopo aver ottenuto una sessione con l'utente **cyber**, è stata avviata una sessione Meterpreter e successivamente è stato utilizzato il modulo Metasploit relativo alla vulnerabilità Dirty Pipe. L'esecuzione del modulo ha portato all'apertura di una nuova sessione con privilegi **root**.

Impatto: Lo sfruttamento della vulnerabilità ha consentito di passare da un utente non privilegiato all'utente **root**, ottenendo il pieno controllo della macchina target. Questo finding rappresenta uno degli elementi più gravi

⁵CWE-78. URL: <https://cwe.mitre.org/data/definitions/78.html>.

dell'intera catena di compromissione.

Soluzione: Aggiornare il kernel Linux a una versione non vulnerabile, applicare le patch di sicurezza disponibili e implementare un processo regolare di patch management. Dopo l'aggiornamento è necessario riavviare il sistema e verificare che la versione vulnerabile non sia più in uso.

Strumenti utilizzati: Usermin, Meterpreter, Metasploit, comandi di enumerazione locale.

Riferimenti: CVE-2022-0847 Dirty Pipe⁶.

6.5 FND-005 – Capability eccessivamente permissiva sul file tar

Severità: High

Asset Interessato: File locale tar

Descrizione: Durante l'analisi locale del sistema è stato individuato un file denominato `tar`, appartenente all'utente `root`, associato alla capability `cap_dac_read_search=ep`. Tale capability consente di leggere file e attraversare directory ignorando le normali restrizioni dei permessi.

PoC: La presenza della capability è stata verificata tramite il comando `getcap`. L'output ha mostrato che il file `tar` disponeva di privilegi aggiuntivi potenzialmente utilizzabili per accedere a file sensibili non leggibili da un utente standard.

Impatto: Un utente non privilegiato potrebbe utilizzare l'eseguibile per leggere file sensibili normalmente non accessibili. Questa configurazione può facilitare la raccolta di credenziali, backup o file di configurazione riservati, diventando un possibile vettore alternativo di escalation o information disclosure.

Soluzione: Rimuovere la capability non necessaria tramite `setcap -r` e

⁶National Vulnerability Database. *CVE-2022-0847 Detail*. Consultato per la descrizione della vulnerabilità Dirty Pipe. 2022. URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-0847>.

revisionare tutte le capabilities assegnate agli eseguibili presenti sul sistema. Le capabilities devono essere concesse solo quando strettamente necessarie e opportunamente documentate.

Strumenti utilizzati: Shell locale, `getcap`, analisi manuale del filesystem.

Riferimenti: CWE-250⁷: Execution with Unnecessary Privileges;
CWE-269⁸: Improper Privilege Management.

6.6 FND-006 – SMB Signing non obbligatorio

Severità: High

Asset Interessato: Servizio SMB/Samba, porte **139/tcp** e **445/tcp**

Descrizione: Durante la scansione automatica è stato rilevato che la firma SMB non risulta obbligatoria. SMB signing è un meccanismo che permette di proteggere l'integrità delle comunicazioni SMB, riducendo il rischio di intercettazione o manipolazione del traffico da parte di un attaccante posizionato nella stessa rete.

PoC: La condizione è stata rilevata tramite scansione Nessus, che ha segnalato il finding *SMB Signing not required*. Il servizio SMB risultava raggiungibile sulle porte **139/tcp** e **445/tcp**.

Impatto: In assenza di firma SMB obbligatoria, un attaccante nella stessa rete potrebbe tentare attacchi di tipo man-in-the-middle o relay, a seconda della configurazione complessiva dell'ambiente. Il rischio è particolarmente rilevante in reti condivise o poco segmentate.

Soluzione: Abilitare e rendere obbligatorio SMB signing, ove compatibile con il contesto operativo. Limitare l'accesso ai servizi SMB tramite firewall, segmentazione di rete e autorizzazioni ristrette.

Strumenti utilizzati: Nessus, Nmap.

Riferimenti: CWE-300⁹: Channel Accessible by Non-Endpoint;

⁷CWE-250. URL: <https://cwe.mitre.org/data/definitions/250.html>.

⁸CWE-269. URL: <https://cwe.mitre.org/data/definitions/269.html>.

⁹CWE-300. URL: <https://cwe.mitre.org/data/definitions/300.html>.

Nessus plugins 57608 - SMB Signing not required¹⁰.

6.7 FND-007 — Information Disclosure tramite servizio SMB

Severità: Medium

Asset Interessato: Servizio SMB/Samba, porte **139/tcp** e **445/tcp**

Descrizione: I servizi SMB/Samba esposti sulle porte **139/tcp** e **445/tcp** hanno consentito di ottenere informazioni relative al sistema target, tra cui il nome NetBIOS della macchina e la presenza dell'utente locale **cyber**.

PoC: L'enumerazione è stata effettuata utilizzando strumenti specifici per SMB/Samba. L'analisi ha permesso di individuare informazioni utili alla successiva fase di exploitation, in particolare lo username **cyber**.

Impatto: L'enumerazione di utenti locali fornisce a un attaccante informazioni utili per costruire attacchi successivi. Nel caso analizzato, l'username individuato è stato combinato con la password recuperata dal codice sorgente, contribuendo direttamente alla catena di compromissione.

Soluzione: Limitare l'accesso ai servizi SMB ai soli host autorizzati, disabilitare l'accesso anonimo, restringere la visibilità di utenti e condivisioni e rivedere la configurazione Samba.

Strumenti utilizzati: smbclient, enum4linux, Nmap.

Riferimenti: CWE-200¹¹: Exposure of Sensitive Information to an Unauthorized Actor;

CWE-497¹²: Exposure of Sensitive System Information to an Unauthorized Control Sphere.

¹⁰*nessus-plugin-57608*. URL: <https://www.tenable.com/plugins/nessus/57608>.

¹¹*CWE-200*. URL: <https://cwe.mitre.org/data/definitions/200.html>.

¹²*CWE-497*. URL: <https://cwe.mitre.org/data/definitions/497.html>.

6.8 FND-008 – Header HTTP di sicurezza mancanti

Severità: Medium

Asset Interessato: Servizio HTTP, porta 80/tcp

Descrizione: L'analisi del servizio HTTP ha evidenziato l'assenza o la configurazione non ottimale di diversi header di sicurezza, tra cui *Content-Security-Policy*, *X-Frame-Options*, *X-Content-Type-Options*, *Referrer-Policy* e *Permissions-Policy*.

PoC: Gli strumenti di analisi web hanno rilevato la mancanza di più header di sicurezza nelle risposte HTTP restituite dal server. Tali risultati sono stati confermati dalle scansioni automatiche e dall'analisi manuale degli header.

Impatto: L'assenza di header di sicurezza non comporta necessariamente una compromissione immediata, ma riduce il livello di hardening dell'applicazione e può aumentare l'impatto di vulnerabilità lato client, come clickjacking, content injection o MIME sniffing.

Soluzione: Configurare header di sicurezza adeguati a livello di web server o applicazione. In particolare, introdurre una Content Security Policy coerente, abilitare `X-Content-Type-Options: nosniff`, configurare protezioni anti-framing e definire policy appropriate per referrer e permessi del browser.

Strumenti utilizzati: Nikto, OWASP ZAP, Nessus.

Riferimenti: CWE-693¹³: Protection Mechanism Failure.

6.9 FND-009 – Directory web navigabili

Severità: Low

Asset Interessato: Servizio HTTP, porta 80/tcp

Descrizione: Durante le attività di content discovery sono state individuate directory web accessibili, tra cui percorsi associati alla documentazione

¹³CWE-693. URL: <https://cwe.mitre.org/data/definitions/693.html>.

Apache, come `/manual/`. Alcune risorse hanno restituito contenuti navigabili o informazioni utili sul server.

PoC: Le directory sono state individuate tramite strumenti di content discovery e confermate tramite accesso manuale via browser. Alcune risorse restituivano codice di risposta positivo o contenuti relativi alla documentazione del web server.

Impatto: La presenza di directory accessibili può facilitare la ricognizione e permettere a un attaccante di individuare file, percorsi o documentazione non necessari all'esposizione pubblica. Nel caso specifico, tale finding ha contribuito alla raccolta di informazioni sul servizio HTTP.

Soluzione: Disabilitare il directory listing, rimuovere la documentazione non necessaria dalla web root e impedire l'accesso pubblico a directory non destinate agli utenti finali.

Strumenti utilizzati: DIRB, dirsearch, Nikto, Nessus, browser web.

Riferimenti: CWE-548¹⁴: Exposure of Information Through Directory Listing

6.10 FND-010 – Esposizione di informazioni di versione

Severità: Low

Asset Interessato: Servizi HTTP e sistema operativo

Descrizione: Il server web espone informazioni relative al software utilizzato, tra cui la versione di Apache e il riferimento alla distribuzione Debian. Tali informazioni sono state rilevate tramite banner, header HTTP e strumenti di fingerprinting.

PoC: Durante l'enumerazione dei servizi e l'analisi degli header HTTP sono state rilevate informazioni come **Apache/2.4.51 (Debian)**. Tali dettagli sono stati confermati anche da strumenti di scansione e fingerprinting.

Impatto: L'esposizione della versione del servizio non consente da sola

¹⁴CWE-548. URL: <https://cwe.mitre.org/data/definitions/548.html>.

la compromissione del sistema, ma facilita le attività di ricognizione e vulnerability mapping, consentendo a un attaccante di cercare exploit o CVE specifiche per i componenti individuati.

Soluzione: Ridurre le informazioni esposte tramite configurazioni come `ServerTokens` e `ServerSignature` in Apache. Mantenere comunque aggiornati i componenti, poiché la rimozione del banner non elimina vulnerabilità eventualmente presenti.

Strumenti utilizzati: Nmap, p0f, Nikto, OWASP ZAP, browser web.

Riferimenti: CWE-497¹⁵: Exposure of Sensitive System Information to an Unauthorized Control Sphere.

6.11 FND-011 – ICMP Timestamp Disclosure

Severità: Low

Asset Interessato: Stack di rete del sistema target

Descrizione: La scansione automatica ha rilevato la possibilità di ottenere informazioni temporali tramite richieste ICMP timestamp. Questo comportamento può fornire dettagli indiretti sul sistema remoto e sul suo stack di rete.

PoC: Il finding è stato rilevato tramite scansione automatica, che ha evidenziato la risposta del target a richieste ICMP timestamp.

Impatto: L'impatto diretto è limitato, ma le informazioni temporali possono contribuire ad attività di fingerprinting e ricognizione, fornendo dati aggiuntivi sul comportamento del sistema remoto.

Soluzione: Valutare la disabilitazione delle risposte ICMP timestamp tramite configurazioni di sistema o firewall, se non necessarie al corretto funzionamento dell'ambiente.

Strumenti utilizzati: Nessus.

Riferimenti: CWE-200¹⁶: Exposure of Sensitive System Information to an

¹⁵ *CWE-497*. URL: <https://cwe.mitre.org/data/definitions/497.html>.

¹⁶ *CWE-200*. URL: <https://cwe.mitre.org/data/definitions/200.html>.

6. DETAILED SUMMARY

Unauthorized Control Sphere.

REFERENCES

- [1] *CWE-615*. URL: <https://cwe.mitre.org/data/definitions/615.html>.
- [2] *CWE-798*. URL: <https://cwe.mitre.org/data/definitions/798.html>.
- [3] *CWE-287*. URL: <https://cwe.mitre.org/data/definitions/287.html>.
- [4] *CWE-306*. URL: <https://cwe.mitre.org/data/definitions/306.html>.
- [5] *CWE-78*. URL: <https://cwe.mitre.org/data/definitions/78.html>.
- [6] National Vulnerability Database. *CVE-2022-0847 Detail*. Consultato per la descrizione della vulnerabilità Dirty Pipe. 2022. URL: <https://nvd.nist.gov/vuln/detail/CVE-2022-0847>.
- [7] *CWE-250*. URL: <https://cwe.mitre.org/data/definitions/250.html>.
- [8] *CWE-269*. URL: <https://cwe.mitre.org/data/definitions/269.html>.
- [9] *CWE-300*. URL: <https://cwe.mitre.org/data/definitions/300.html>.

REFERENCES

- [10] *nessus-plugin-57608*. URL: <https://www.tenable.com/plugins/nessus/57608>.
- [11] *CWE-200*. URL: <https://cwe.mitre.org/data/definitions/200.html>.
- [12] *CWE-497*. URL: <https://cwe.mitre.org/data/definitions/497.html>.
- [13] *CWE-693*. URL: <https://cwe.mitre.org/data/definitions/693.html>.
- [14] *CWE-548*. URL: <https://cwe.mitre.org/data/definitions/548.html>.